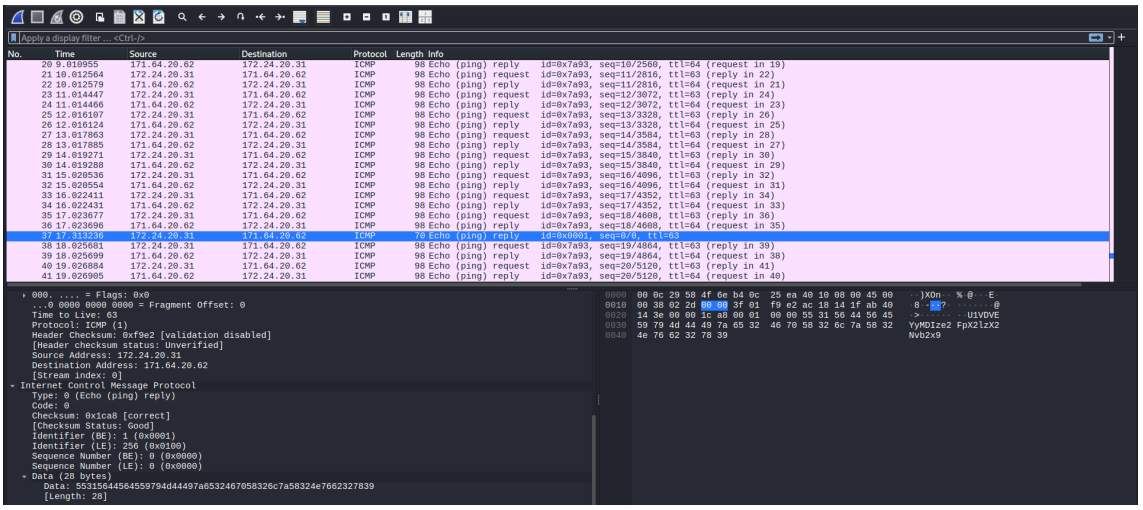
SUBJECT	VULNERABILITY ANALYSIS
CODE	IKB21004 & IKB21403
TASK	FILE ANALYSIS – SCANNING RESULT

Question 1: Analyses **packet1.pcap** and find the flag.



No.	Time	Source	Destination	Protocol	Length	Info
20	9.010955	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0x7a93, seq=10/2560, ttl=64 (request in 19)
21	10.012564	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0x7a93, seq=11/2816, ttl=63 (reply in 22)
22	10.012579	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0x7a93, seq=11/2816, ttl=64 (request in 21)
23	11.014447	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0x7a93, seq=12/3072, ttl=63 (reply in 24)
24	11.014466	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0x7a93, seq=12/3072, ttl=64 (request in 23)
25	12.016107	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0x7a93, seq=13/3328, ttl=63 (reply in 26)
26	12.016124	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0x7a93, seq=13/3328, ttl=64 (request in 25)
27	13.017863	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0x7a93, seq=14/3584, ttl=63 (reply in 28)
28	13.017885	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0x7a93, seq=14/3584, ttl=64 (request in 27)
29	14.019271	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0x7a93, seq=15/3840, ttl=63 (reply in 30)
30	14.019288	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0x7a93, seq=15/3840, ttl=64 (request in 29)
31	15.020536	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0x7a93, seq=16/4096, ttl=63 (reply in 32)
32	15.020554	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0x7a93, seq=16/4096, ttl=64 (request in 31)
33	16.022411	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0x7a93, seq=17/4352, ttl=63 (reply in 34)
34	16.022431	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0x7a93, seq=17/4352, ttl=64 (request in 33)
35	17.023677	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0x7a93, seq=18/4608, ttl=63 (reply in 36)
36	17.023696	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0x7a93, seq=18/4608, ttl=64 (request in 35)
37	17.319230	172.24.20.31	171.64.20.62	ICMP	70	Echo (ping) reply id=0x0001, seq=0/0, ttl=63
38	18.025681	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0x7a93, seq=19/4864, ttl=63 (reply in 39)
39	18.025699	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0x7a93, seq=19/4864, ttl=64 (request in 38)
40	19.026884	172.24.20.31	171.64.20.62	ICMP	98	Echo (ping) request id=0x7a93, seq=20/5120, ttl=63 (reply in 41)
41	19.026905	171.64.20.62	172.24.20.31	ICMP	98	Echo (ping) reply id=0x7a93, seq=20/5120, ttl=64 (request in 40)

```
▸ 000. .... = Flags: 0x0
  ...0 0000 0000 0000 = Fragment Offset: 0
  Time to Live: 63
  Protocol: ICMP (1)
  Header Checksum: 0xf9e2 [validation disabled]
  [Header checksum status: Unverified]
  Source Address: 172.24.20.31
  Destination Address: 171.64.20.62
  [Stream index: 0]
▾ Internet Control Message Protocol
  Type: 0 (Echo (ping) reply)
  Code: 0
  Checksum: 0x1ca8 [correct]
  [Checksum Status: Good]
  Identifier (BE): 1 (0x0001)
  Identifier (LE): 256 (0x0100)
  Sequence Number (BE): 0 (0x0000)
  Sequence Number (LE): 0 (0x0000)
  ▾ Data (28 bytes)
    Data: 5531564456455979 4d44497a6532467058326c7a58324e7662327839
    [Length: 28]
```

```
0000  00 0c 29 58 4f 6e b4 0c  25 ea 40 10 08 00 45 00   ··)XOn·· %·@···E·
0010  00 38 02 2d 00 00 3f 01  f9 e2 ac 18 14 1f ab 40   ·8·-··?· ·------@
0020  14 3e 00 00 1c a8 00 01  00 00 55 31 56 44 56 45   ·>------ ··U1VDVE
0030  59 79 4d 44 49 7a 65 32  46 70 58 32 6c 7a 58 32   YyMDIze2 FpX2lzX2
0040  4e 76 62 32 78 39                                  Nvb2x9
```

Figure 1 Wireshark

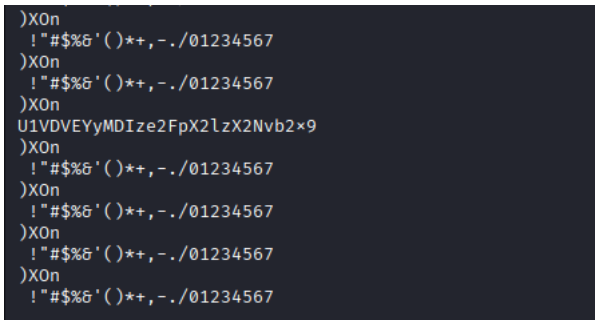


Figure 2 Comparing Raw ASCII Output

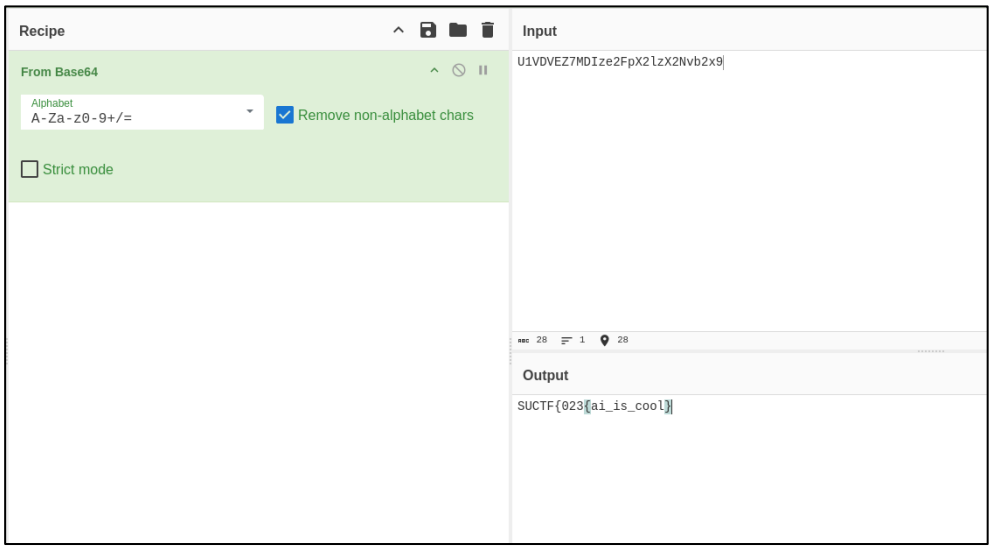


Figure 3 Base64 Decryption

Analysis :

When opening the file in Wireshark, I observed that every packet are ICMP (Internet Control Message Protocol), which known as “ping”. When observing each packet, I notice **packet 37** appeared as a “Reply” immediately after another “Reply”, which not normal is standard Request-reply sequence. This behavior is exactly like ICMP Data Exfiltration, which an attacker hides secret information inside the data payload of a ping packet to bypass the firewalls.

Question 2: Analyses **packet2.pcap** and find the flag.

Question 3: Interpret an Nmap Output

Table 1 Nmap Result

PORT	STATE	SERVICE	VERSION
21/tcp	Open	ftp	Vsftpd 2.3.4
22/tcp	Open	Ssh	OpenSSH 5.3p1
5.3p1 80/tcp	Open	http	Apache 2.2.8
139/tcp	Open	Netbios-ssn	(NetBIOS service)
445/tcp	open	Microsoft-ds	Windows 7 Professional 7601 Service Pack 1

Questions:

1. What can an attacker do with each port?
2. What vulnerabilities are likely present based on the version?
3. Which one is the highest risk and why?
4. What attack path can be built from this?
5. What should be the remediation?

Answer

Questions 1 :

Table 2 Service an Attack Options

Port	Service	Potential Attacker Actions
21	FTP	Attacker can login anonymously, brute-force credentials, or setup a backdoor command if the version is outdated.
22	SSH	Attacker can attempt to gain remote terminal access by credential stealing or using brute-force attack to gain password.
80	HTTP	Can exploit the web vulnerabilities such as directory traversal, SQL injection, or exploit an outdated web server modules.
139/445	SMB	Can enumerate the network shares, list the owner account or attempt a Remote Code Execution attacks.

Questions 2 :

1) vsftpd 2.3.4 (port 21) – Is a famous hall of fame vulnerability especially for Backdoor Command Execution (CVE-2011-2523) where sending a specific string such as **:)** as a username can triggers the shell on port 6200.

2) Apache 2.2.8 (Port 80) – This version is quite old and might be a susceptible to a multiple Denial of Service (DoS) attacks and potential Cross-Site Scripting (XSS) vulnerabilities.

3) Windows 7 Professional SP1 (Port 445) – This was a biggest flaw. Windows 7 is popular for **EternalBlue (MS17-010)** exploitation, which allows an attacker to maneuver the overall system without even needing a password.

Questions 3 :

1) Port 21 – Since the exploit can be instantiable, an attacker doesn't need to guess anything; they can just trigger the backdoor and get the root access immediately.

2) Port 445 – EternalBlue notorious for its dangerous level, it is extremely powerful due to full systems compromise and lets the attack to hop to other computers on the same network.

Questions 4 :

1) Reconnaissance – First, attacker will collect the scanning result and identify the weak points.

2) Gaining Access – Trigger the **vsftpd 2.3.4 backdoor** on Port 21 to get a blueprint in the door.

3) Escalate Privileges – Use the access to find a local admin credentials or system hashes.

4) Maintaining Access – Use the **EternalBlue exploit** on port 445 to access to other Windows 7 machines in the lab.

Questions 5 :

1) Update/patch Services : Critical steps than can be emphasize is upgrading the Windows 7 to modern and supported OS such as Windows 10 or 11.

2) Replace Insecure Services : Uninstall the **vsftpd 2.3.4** and replace it with more secure version of FTP, or using a SFTP for more secure FTP functions.

3) Disable Unnecessary Ports : If the lab doesn't need a web server or FTP services, turn off port 80 and port 21 can be a great secure movement to avoid malicious scanning and attacks.

4) Firewall : Block SMB (port 445) from being accessed by anything outside the local network.

Question 4: Identify the OS (OS Fingerprinting) - TTL

≥ Image 1

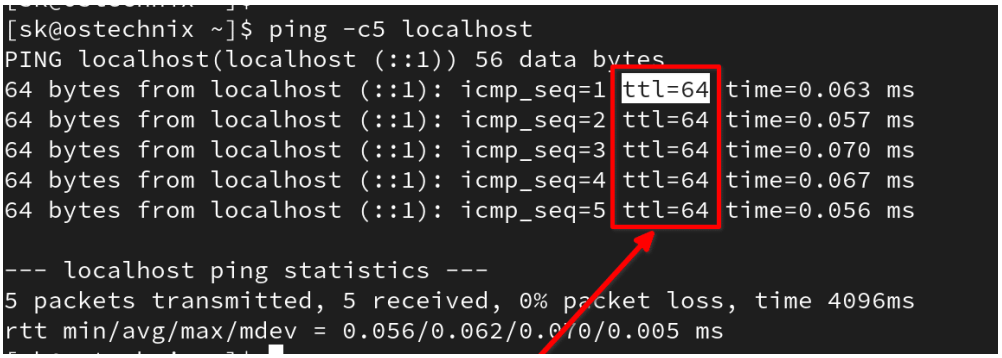


Figure 4 Operating System Fingerprinting via ICMP TTTL

Answer :

Possible Operating System – Linux or another Unix-based system

Reason :

The screenshot displays a consistent value of **ttl=64**. Due to the ping localhost command, the packets are staying inside the machine and not passing to any routers. This means the value shown is original, default TTL which set by the operating system's kernel.

≥ Image 2

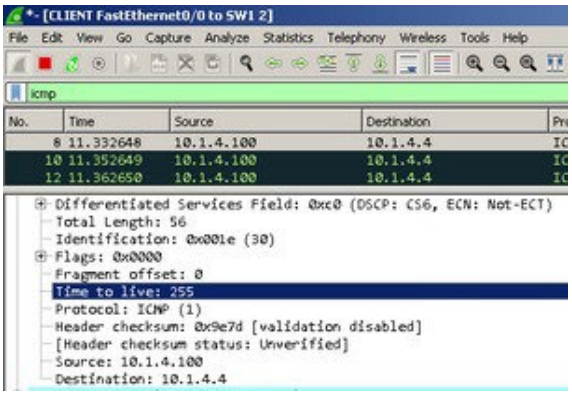


Figure 5 Packet Capture

Answer :

The device may be **Network Infrastructure Device** (most likely known as Cisco Router or Switch) or a system running Solaris.

Reason :

The packet captured clearly shows **Time to live: 255**. This is a maximum possible TTL value. It is the signature for networking hardware such as Cisco routers or servers like Solaris. For more details, Linux or Unix usually commence at 64 while Windows usually commence at 128. Since its still 255, it high chance that the packet hasn’t passed any routers yet.

Image 3:

```
64 bytes from 192.168.122.239: icmp_seq=1 ttl=128 time=6.85 ms
64 bytes from 192.168.122.239: icmp_seq=2 ttl=128 time=0.510 ms
64 bytes from 192.168.122.239: icmp_seq=3 ttl=128 time=0.601 ms
64 bytes from 192.168.122.239: icmp_seq=4 ttl=128 time=0.541 ms
64 bytes from 192.168.122.239: icmp_seq=5 ttl=128 time=0.558 ms
```

Figure 6 Ping Result for Target IP

Answer :

Based on the screenshot, I think the machine is running on Microsoft Windows.

Reason :

The proof is TTL (Time to live) value since the 128 is classic default TTL for all versions of Windows 10 and above. In the ping results, every reply from **192.168.122.239** has **ttl-128**, which exactly same like the Windows default. Since the TTL decreases as packets traverse through routers, 128 is likely reachable on the local network and running Windows.

Question 5: Analyses the Nessus file

Upload to your nessus (Network_Scan.nessus) and analyse the files. Focus on critical or high findings that was identifies in analysis named “Ghostcat”.

1. What is the affected Port number

   8009
2. What is the Affected protocol

   TCP
3. What is the CVSS Score of vulnerability found

   9.8
4. Can you find any exploit related to this vulnerability?

Yes, exploits are available

5. Find CVE for this vulnerability.

   CVE-2020-1938